# UD 7
# Administración del control de accesos adecuados de los sistemas de información





## Requisitos de negocio para el control de accesos

- El control de accesos en una organización es la forma más básica para controlar el acceso a:
  - La información
  - Los medios de procesamiento de la información
  - Los procesos de negocio de la organización
- El punto de partida es establecer una política de control de accesos adecuada, documentada y actualizada en el tiempo que contemple:
  - Reglas de acceso para usuarios y grupos
  - Controles físicos y lógicos

# Alcance de la política de control de accesos

- Requerimientos de seguridad de las aplicaciones
- Identificación de la información sensible en las apps y sus riesgos
- Criterios de divulgación y autorización de uso de la información
- Coherencia ente control de acceso y la clasificación de la información
- Imperativos legales y contractuales
- Perfiles de acceso por tipología de usuario y sus roles
- Extendidos y adaptados a cada tipo de conexión posible
- Operativa de autorización, revocación y revisión de derechos y controles





# Criterios para definir los controles

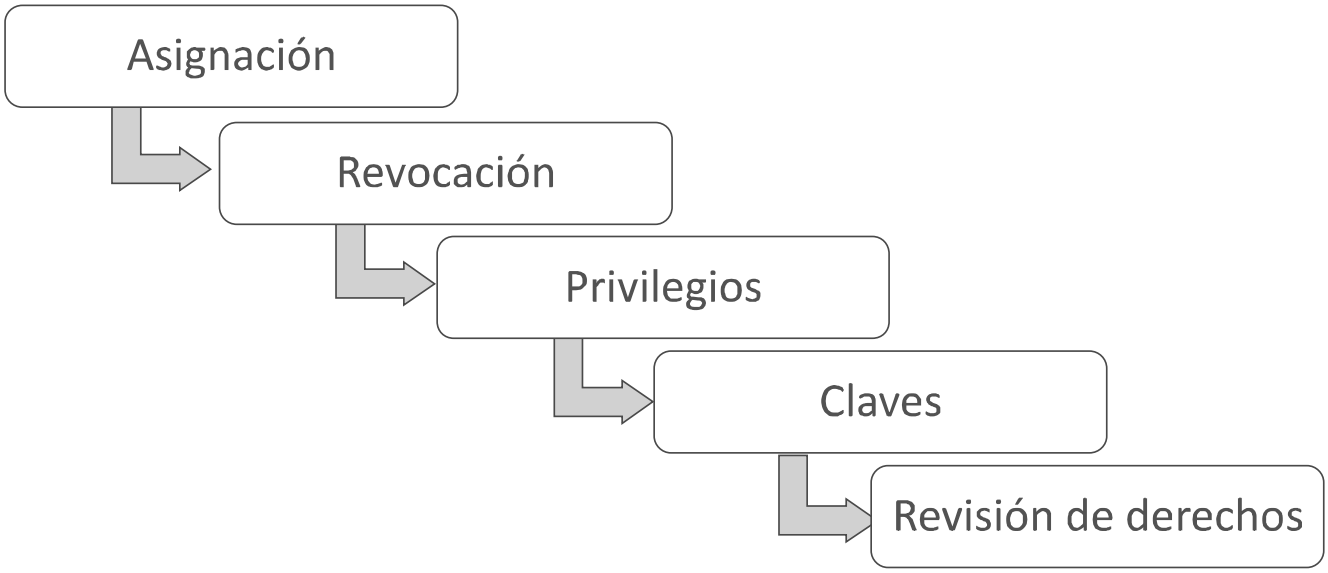
Diferencia entre reglas obligadas y recomendadas

Premisa: *todo está prohibido salvo que se autorice expresamente*

Diferenciación

- Tratamiento de información automático vs manual
- Usuario con alta automático vs manual por el administrador
- Reglas nuevas que necesitan aprobación vs no necesitan

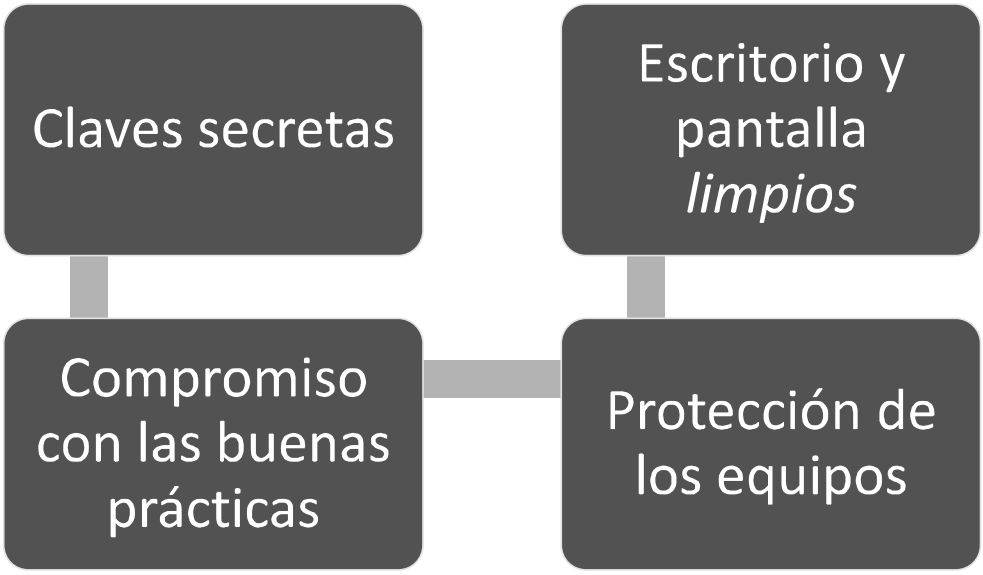
# Requerimientos de diseño de la política I
# → Gestión de acceso del usuario








# Requerimientos de diseño de la política II
# → Responsabilidades del usuario



# Requerimientos de diseño de la política III → Control de acceso a la red

| | | | |
|---|---|---|---|
| Relación usuario → accesos autorizados | Control acceso remoto | Identificación de equipos | Control equipo ↔ ubicaciones |
| Protección de puertos con control de acceso físico y lógico | Segregación redes usuarios ↔ servicio IT | Restricciones en redes compartidas | Controles de enrutamiento |

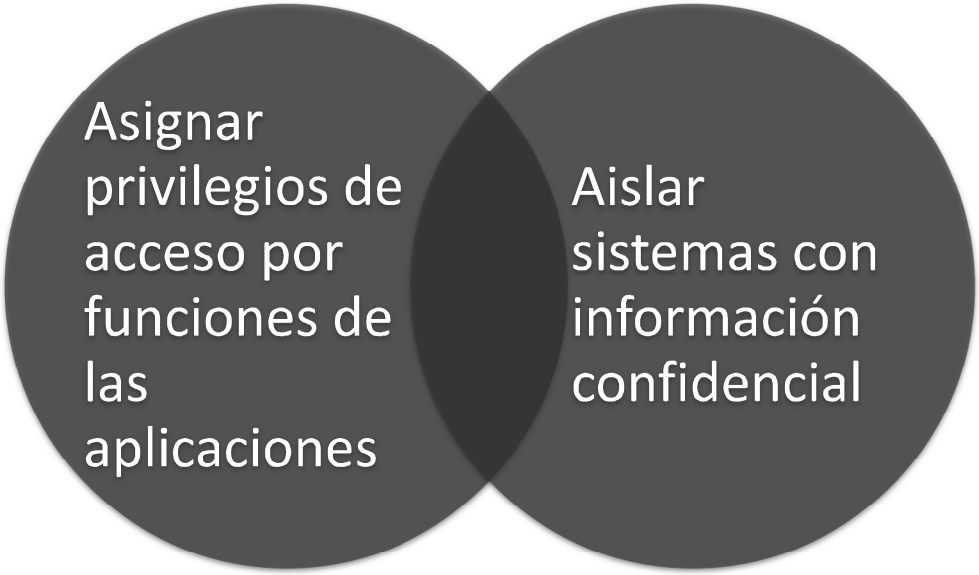




# Requerimientos de diseño de la política IV → Control de acceso al SO

- Registro (*login*) seguro
- Identificador único de usuario
- Sistemas gestión de claves interactivos y seguros
- Uso restringido de utilidades del SO
- Cierre automático de sesiones inactivas

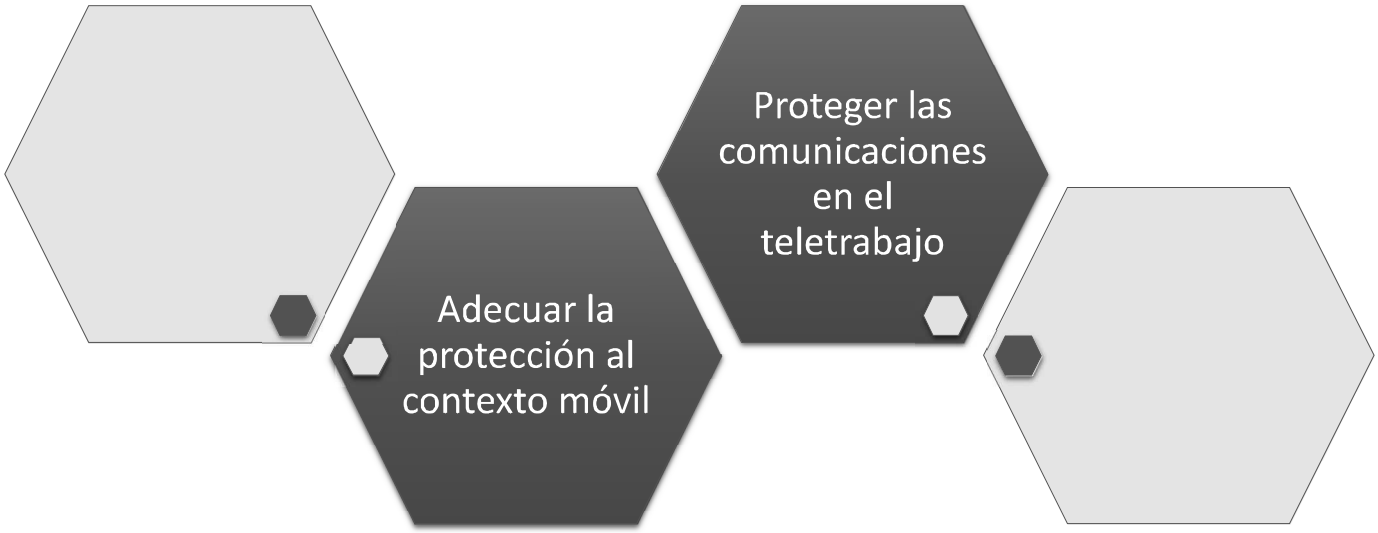
# Requerimientos de diseño de la política V
# → Control de acceso a aplicación e información








# Requerimientos de diseño de la política VI
# → Informática móvil y teletrabajo



# Registro de usuario

- ✓Identificadores individuales, no grupales.
- ✓Verificar autorización expresa al recurso
- ✓Comprobar nivel usuario adecuado al uso
- ✓Informar por escrito los derechos de acceso, con acuse de recibo
- ✓Proveedores restringidos hasta completar autorización
- ✓Registro formal de autorizaciones
- ✓Gestión de la salida del personal con bloqueo inmediato
- ✓Verificar unicidad de las autorizaciones
- ✓Clausulas adecuadas en contratos, incluso con sanciones





# Gestión de privilegios
## Implantar procedimiento de gestión de privilegios

- Asignación de privilegios por recurso (software, hardware, red…)
- Seguir el principio: *Los usuarios deben poder acceder solo a lo que deben saber*
- Crear y ligar rutinas del sistema que eviten asignaciones innecesarias
- Realizar la asignación como una transacción, de modo que hasta que no esté finalizada por completo la autorización, no se asignarán los privilegios.
- Mantener actualizado el procedimiento y el registro de privilegios

Windows: Inicio -> Panel de control -> Cuentas de usuario.

# Gestión de contraseñas de usuario
## Procedimiento de gestión de contraseñas

- Compromiso formal de confidencialidad de los usuarios respecto a las contraseñas (propias y grupales)
- Inicialmente contraseña de un solo uso
- Verificación de identidad antes de dar nueva contraseña
- Entrega de contraseñas por medio seguro (evitar correo, intermediarios, etc.)
- Acuse de recibo de la contraseña
- Usuario guardarán las contraseñan en ***lugar seguro***
- En software nuevo, sustituir en el primer uso la contraseña de origen





# Revisión de los derechos de acceso de los usuarios

- Periódicamente y por cambio de circunstancias del usuario (salida de la empresa, cambio de puesto, etc.)
- Por los responsables
- Período de revisión más corto para privilegios elevados
- Registro de cambios

# Obligaciones legales en control de accesos y privilegios (LOPD & RGPD & LSSI) - I

**Niveles de seguridad**

**Nivel Básico**

Para todos los ficheros de datos de carácter personal.

**Nivel Medio**

Ficheros que contengan datos relativos a la comisión de infracciones administrativas o penales.

Ficheros que contengan datos sobre Hacienda Pública.

Ficheros que contengan datos sobre servicios financieros.

Ficheros que contengan datos sobre solvencia patrimonial y crédito.

Ficheros que contengan un conjunto de datos suficientes que permitan elaborar un perfil del afectado.

**Nivel alto**

Ficheros que contengan datos referentes a la ideología, religión, creencias, origen racial, salud o vida sexual del interesado



MF 1 - Gestión de Servicios en el Sistema Informático MF0490_3
UD 7 Administración del control de accesos adecuados de los sistemas de información

# Obligaciones legales en control de accesos y privilegios (LOPD & RGPD & LSSI) - I

**Niveles de seguridad**

| Nivel Básico | Nivel Medio | | | | | Nivel alto |
|---|---|---|---|---|---|---|
| Para todos los ficheros de datos de carácter personal. | Ficheros que contengan datos relativos a la comisión de infracciones administrativas o penales. | Ficheros que contengan datos sobre Hacienda Pública. | Ficheros que contengan datos sobre servicios financieros. | Ficheros que contengan datos sobre solvencia patrimonial y crédito. | Ficheros que contengan un conjunto de datos suficientes que permitan elaborar un perfil del afectado. | Ficheros que contengan datos referentes a la ideología, religión, creencias, origen racial, salud o vida sexual del interesado |

# Obligaciones legales en control de accesos y privilegios (LOPD & RGPD & LSSI) - II

| MEDIDAS DE SEGURIDAD | Alto | Medio | Bajo |
|---|---|---|---|
| Acceso autorizado solo a los datos necesarios. | | | ✓ |
| Establecimiento de mecanismos para evitar el acceso de usuarios con derechos distintos a los autorizados (responsable del fichero). | | | ✓ |
| Relación de usuarios que contenga el acceso autorizado de cada uno de ellos. | | | ✓ |
| La concesión, alteración y/o anulación del acceso autorizado solo puede realizarla el personal autorizado en el documento de seguridad. | | | ✓ |
| El responsable del fichero debe establecer un mecanismo para identificar a los usuarios que intentan acceder al sistema. | | ✓ | ✓ |
| Limitación de los intentos reiterados de accesos no autorizados. | | ✓ | ✓ |

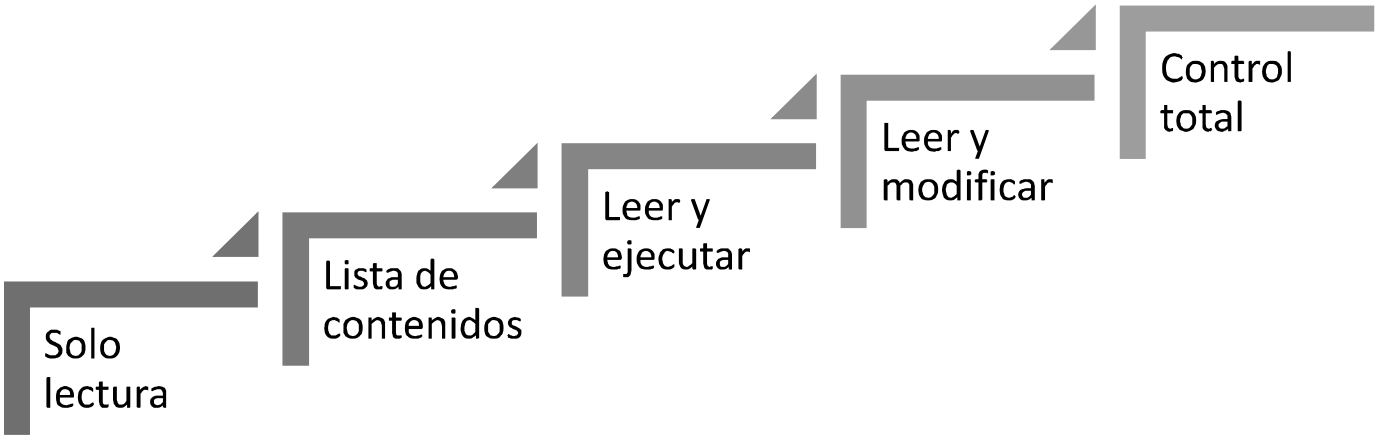




# Obligaciones legales en control de accesos y privilegios (LOPD & RGPD & LSSI) - III

| MEDIDAS DE SEGURIDAD | Alto | Medio | Bajo |
|---|---|---|---|
| Control de acceso físico limitado al personal autorizado en el documento de seguridad. | | ✓ | ✓ |
| Almacenamiento de la identificación, fecha y hora del acceso, fichero accedido, tipo de acceso y acceso autorizado/denegado en cada acceso. | ✓ | ✓ | ✓ |
| En accesos autorizados, almacenamiento de la información que identifique al registro accedido. | ✓ | ✓ | ✓ |
| El responsable de seguridad debe controlar directamente los mecanismos de registro de los datos. | ✓ | ✓ | ✓ |
| Conservación de los datos: mínimo dos años. | ✓ | ✓ | ✓ |
| Revisión de la información de control y elaboración de informes: una vez al mes por el responsable de seguridad. | ✓ | ✓ | ✓ |

# Perfiles de acceso (por departamento, rol, nivel puesto, …)








# Directorio Activo

Servicio de directorio que permite gestionar todos los elementos de una red

- Equipos
- Usuarios y Grupos
- Dominios
- Políticas de seguridad
- Recursos compartidos: impresión, discos, …

# Funciones del Directorio Activo
## Gestión de inequívoca de identidad

- Repositorio central de usuario, servidores y puestos
- Mínimo número de repositorios necesarios
- Políticas de seguridad, validación y autorización





# Funciones del Directorio Activo II
## Seguridad

- Localización y acceso a recursos de forma organizada y simplificada
- Herramienta de gestión unificada
- Automatización de bloqueo de Sistemas Operativos
- Uso reforzado de contraseñas y credenciales
- Delegación de tareas administrativas

# Funciones del Directorio Activo III
## Gestión de la Configuración de Elementos de RED

### Objetivos:

- Aumento de productividad
- Reducción de costes de administración, soporte y aprendizaje

### Funciones:

- Gestión uno a muchos de usuarios y equipos
- Automatización de forzado de políticas de seguridad
- Implementación eficiente de configuraciones estándar para usuarios, grupos y equipos





# Protocolos de Directorio Activo I
## LDAP (1)

**LDAP :: Protocolo Ligero de Acceso a Directorio***

Protocolo a nivel de aplicación que permite el acceso a un servicio de directorio ordenado y distribuido para buscar diversa información en un entorno de red.

**Lightweight Directory Access Protocol*

# Protocolos de Directorio Activo I
## LDAP (2)

**LDAP :: Protocolo Ligero de Acceso a Directorio***

Sus entradas tienen estructura de árbol invertido, con pares clave/valor. Cada entrada de LDAP posee un grupo de atributos con Nombre Global Distinguido. Las claves más utilizadas son:

**uid**: identificación única obligatoria.
**cn** (*common name*): nombre de la persona.
**givenname**: nombre de pila de la persona.
**sn** (*surname*): apellido de la persona.
**o** (*organization*): organización donde trabaja la persona.
**u**: unidad o departamento en el que trabaja la persona.
**mail**: correo electrónico de la persona.

**Lightweight Directory Access Protocol*





# Protocolos de Directorio Activo II
## DNS

**DNS :: Sistema de Nombres de Dominio***

Conjunto de protocolos y servicios que permite a los usuarios utilizar nombres en vez de tener que recordar direcciones IP numéricas.

**Domain Name System*

# Protocolos de Directorio Activo III
## DHCP

**DHCP :: Protocolo de Configuración Dinámica de Anfitrión***

Protocolo cliente/servidor que proporciona automáticamente un host de Protocolo de Internet (IP) con su dirección IP y otra información de configuración relacionada, como la máscara de subred y la puerta de enlace predeterminada

**Dynamic Host Configuration Protocol*





# Protocolos de Directorio Activo IV
## Kerberos

**Kerberos :: Protocolo de autenticación de redes**

Protocolo cliente/servidor que permite a dos computadores en una red insegura demostrar su identidad mutuamente de manera segura.

# Herramientas de Directorio Activo y LDAP

Active Directory (Windows server)

OpenLDAP

Apache Directory Server & Apache Directory Studio



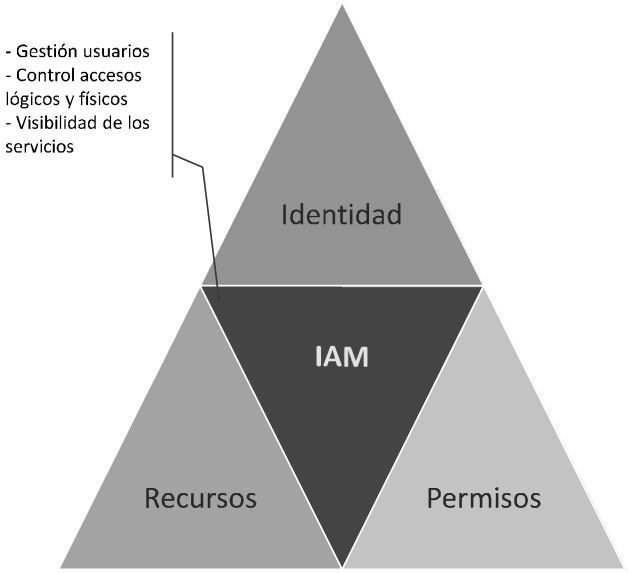
MF 1 - Gestión de Servicios en el Sistema Informático MF0490_3
UD 7 -Administración del control de accesos adecuados de los sistemas de información

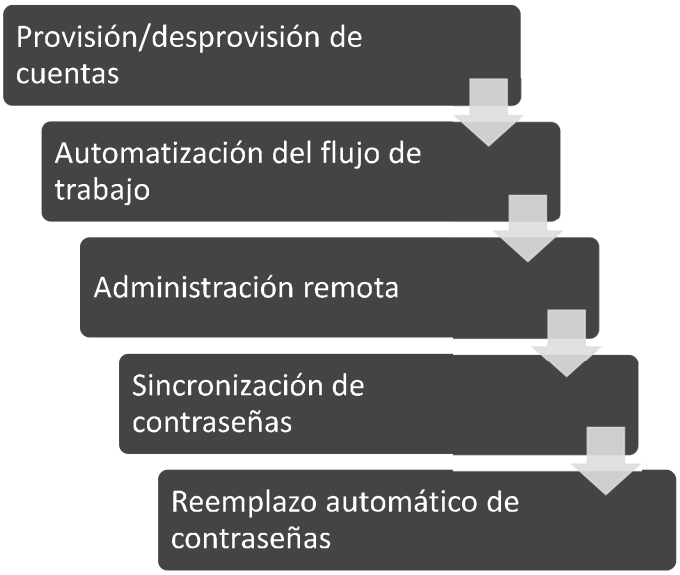
# Identidad

- Representación de un individuo o entidad dentro de un sistema de información.
- Permite distinguir a un usuario de los demás.
- Un perfil de identidad incluye aspectos como:
  - Identificación única.
  - Información personal del usuario.
  - Credenciales de autenticación.
  - Permisos de acceso y roles asignados al usuario.

**Identity*

# Gestión de Accesos e Identidades – *IAM**




**Identity and Access Management*

*Oracle Identity Manager / OPEN ID*





# Punto Único de Autenticación - SSO*

- Acceso a todos los servicios del sistema con una única identificación
- Tipos de herramientas:
  - Enterprise Single Sign-On (E-SSO) o Legacy Single Sign-On
  - Web Single Sign-On (Web-SSO) o Web Access Management (Web-AM)
  - Kerberos
  - OpenID
  - OpenAM (Identidad federada)

** Single Sign On*

# Gracias